CYBERSECURITY INTERNSHIP WEEK 6 REPORT

WEB SECURITY & VULNERABILITY TESTING

Submitted by: Deepashree.C

Role: Cybersecurity Intern

Week: Week 6

SIN: DG/SEPTEMBER/CYBER/254

Submitted to: DG Interns Hub

Topics: VAPT • OWASP vulnerabilities • SQL Injection • XSS • Burp Suite • OWASP ZAP • DVWA

1. Introduction

Vulnerability Assessment and Penetration Testing (VAPT) is a security testing process used to identify, analyze, and validate vulnerabilities in systems and web applications. The Week 6 assignment focused on common web application weaknesses and practical testing in an authorized lab environment.

The main objectives were to:

- Identify web application security weaknesses.
- Understand common vulnerabilities in an authorized environment.
- Analyze HTTP requests and responses.
- Assess risk levels and potential impacts.
- Recommend suitable mitigation techniques.

2. Testing Environment and Tools

The practical work used DVWA (Damn Vulnerable Web Application) as the target in a local or authorized lab. Burp Suite was used for manual HTTP traffic inspection, and OWASP ZAP was used for automated vulnerability scanning. The approach combined manual testing with automated scanning.

Component	Description
Target	DVWA (Damn Vulnerable Web Application)
Environment	Local / authorized lab
Tools	Burp Suite and OWASP ZAP
Approach	Manual testing and automated scanning

3. Overview of OWASP Vulnerabilities

The assignment covered Broken Authentication and Security Misconfiguration, including their likely impacts and preventive controls.

Vulnerability	Description	Potential impact	Prevention
Broken Authentication	Weak authentication or improper session handling.	Account hijacking, identity theft and unauthorized access.	Strong passwords, MFA, secure session management and login rate limiting.
Security Misconfiguration	Incorrect or insecure application, server or system settings.	Data leakage, unauthorized access and privilege escalation.	Disable default accounts, patch systems, remove unnecessary services and conduct regular audits.

4. SQL Injection Testing

SQL Injection occurs when untrusted input is handled incorrectly in SQL queries, potentially allowing an attacker to interfere with database operations. In the DVWA SQL Injection module, controlled test inputs were submitted, application responses were observed, and HTTP requests were inspected using Burp Suite.

Potential impact

- Unauthorized access to database records.
- Exposure or modification of sensitive information.
- Potential authentication bypass.

Mitigation

- Use prepared statements and parameterized queries.
- Validate user input appropriately.
- Apply least-privilege permissions to database accounts.
- Avoid constructing SQL queries through direct string concatenation.

5. Cross-Site Scripting (XSS)

Cross-Site Scripting is a web vulnerability in which improperly handled user input is interpreted as executable code in a user's browser. The assignment covered two types:

- Reflected XSS: input is reflected in the application's response and may execute immediately in the browser.
- Stored XSS: untrusted input is saved by the application and may execute when another user views the affected content.

Reflected and Stored XSS were tested in DVWA using controlled inputs. Browser-side behavior was observed, and HTTP requests were captured and analyzed with Burp Suite.

Mitigation

- Apply context-aware output encoding.
- Validate and sanitize user input where appropriate.
- Implement a Content Security Policy (CSP).
- Handle user-generated content securely.

6. Burp Suite: HTTP Request and Response Analysis

Burp Suite was used as an interception proxy to inspect HTTP communication between the browser and DVWA. The activities included capturing requests, analyzing parameters and user inputs, reviewing server responses and status codes, and observing application behavior during vulnerability testing.

Evidence considered included HTTP methods and URLs, request parameters and test inputs, response status codes and content, and observed application behavior.

7. OWASP ZAP Scanning and Findings

OWASP ZAP was used to scan the authorized DVWA environment for potential web application security issues. The process involved configuring the target, crawling pages and endpoints, running an automated scan, and reviewing alerts.

Risk category	Meaning in the assignment
High	Critical security concerns.
Medium	Potentially exploitable weaknesses.
Low	Minor security issues.

Informational	Observations and security recommendations.

The alerts were reviewed to consider potential impact, verify relevant findings, and recommend mitigation. The source slides do not provide specific alert names, counts, or confirmed severity results; therefore, this report does not claim particular scan findings.

8. VAPT Workflow

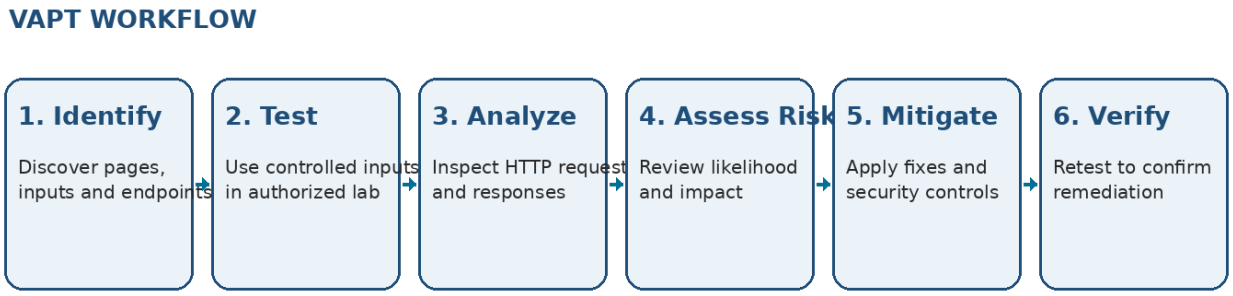


Figure 1. General workflow summarizing the assignment's key learning: Identify → Test → Analyze → Evaluate Risk → Mitigate → Verify.

9. Mitigation Recommendations

- Use parameterized queries to prevent SQL Injection.
- Validate user input and apply context-aware output encoding to reduce XSS risk.
- Implement strong authentication and secure session handling.
- Remove insecure configurations and disable unnecessary services.
- Update software and dependencies regularly.
- Configure appropriate security headers.
- Conduct periodic vulnerability assessments and penetration testing.

10. Conclusion and Learning Outcomes

The Week 6 practical introduced web application security testing using DVWA in an authorized lab environment. Burp Suite supported HTTP traffic inspection, while OWASP ZAP supported automated scanning for potential security issues. The SQL Injection and XSS exercises illustrated common web application risks and the importance of effective security controls.

The main learning sequence was: Identify → Test → Analyze → Evaluate Risk → Mitigate → Verify.

Note: The original presentation labels several screenshots as figures, but the extracted slide content did not expose all of those images as embedded picture objects. The report therefore includes an original workflow illustration and retains the technical content without inventing screenshots or scan results.

Appendix A. Visual Evidence from the Week 6 Presentation

The following images are included from the supplied presentation as supporting visual evidence. Captions identify the source slide; technical interpretations are limited to the report content.



Figure A1. Overview image from the presentation (source slide 2).



Figure A2. SQL Injection testing evidence (source slide 4).

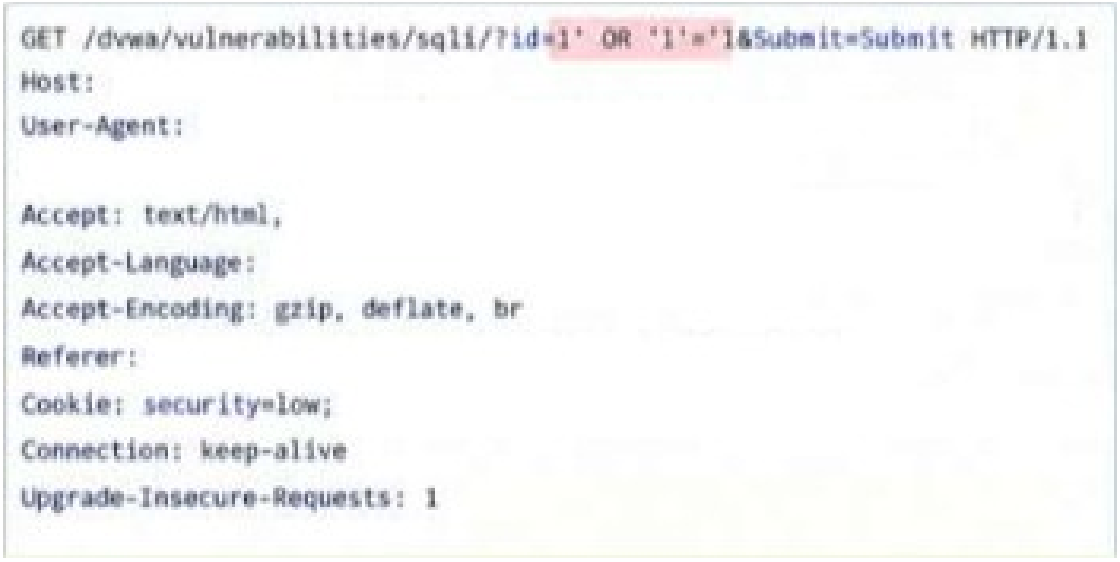


Figure A3. SQL Injection testing evidence (source slide 4).

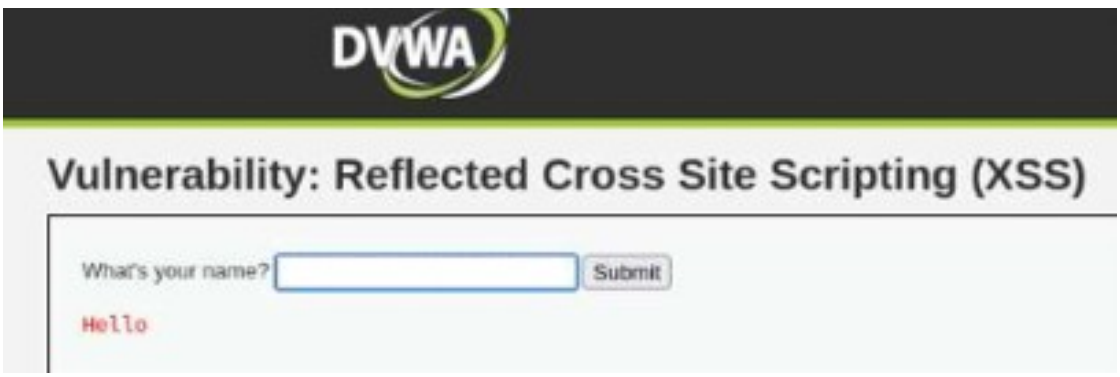


Figure A4. XSS testing evidence (source slide 5).



Figure A5. XSS testing evidence (source slide 5).

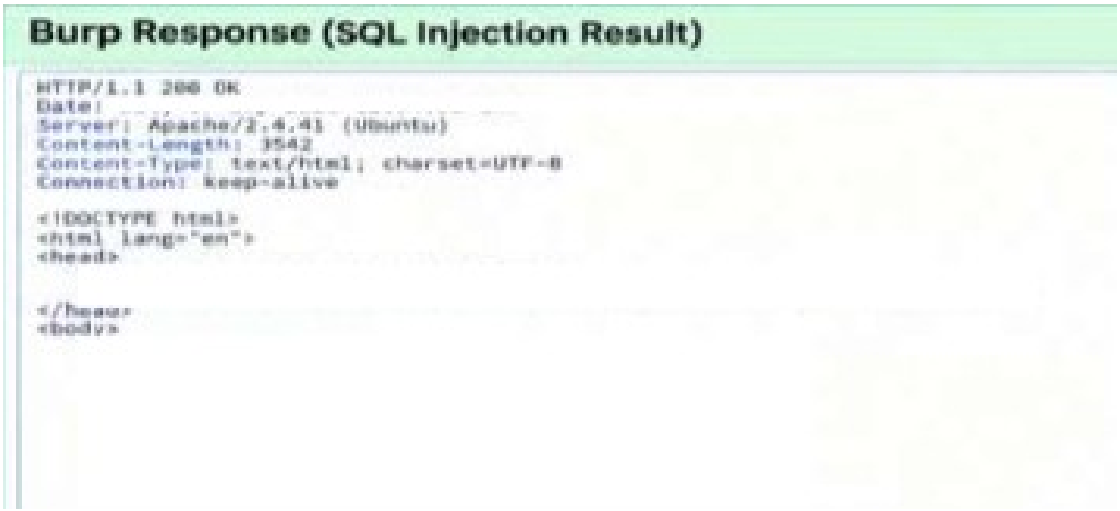


Figure A6. Burp Suite HTTP traffic analysis evidence (source slide 6).



Figure A7. Burp Suite HTTP traffic analysis evidence (source slide 6).



Figure A8. OWASP ZAP scanning evidence (source slide 7).

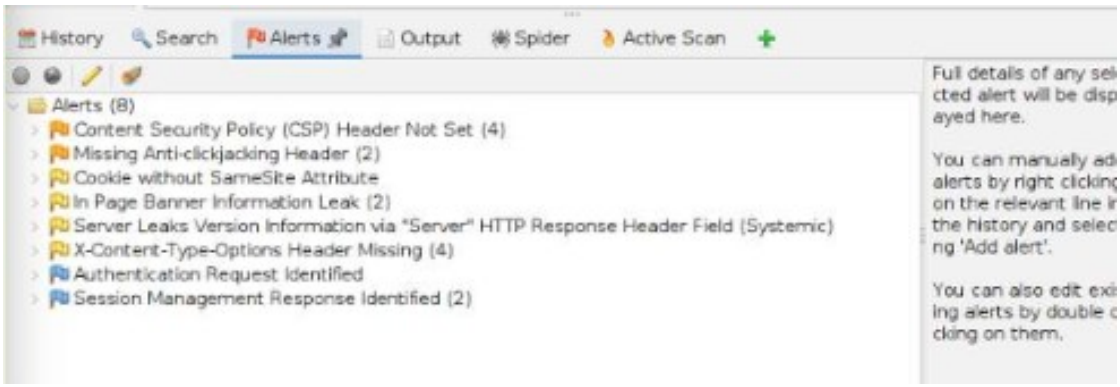


Figure A9. OWASP ZAP target configuration evidence (source slide 7).